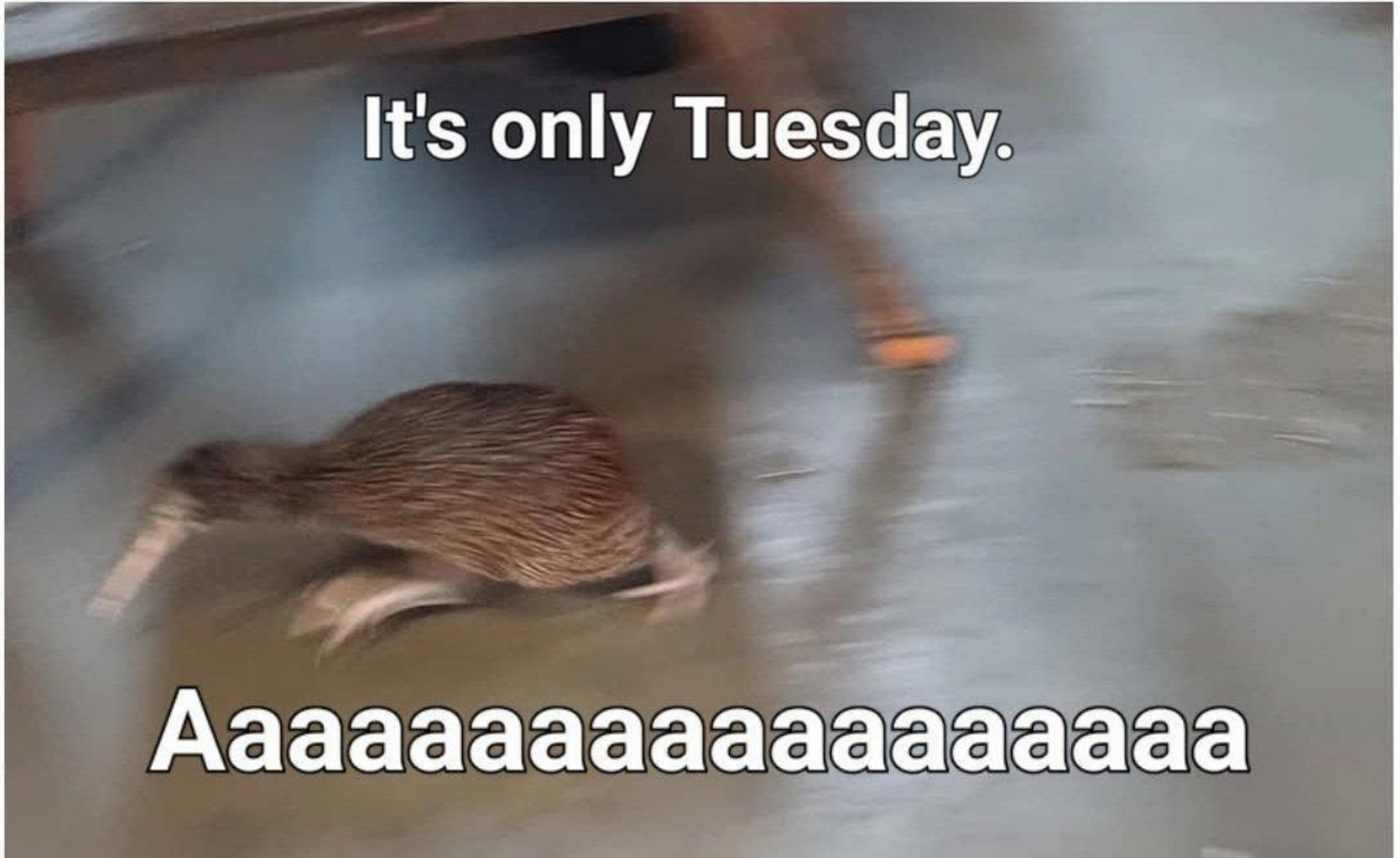
SecKC September News

By @net_code / Isaiah


It's only Tuesday.
Aaaaaaaaaaaaaaaaaa

Vulns



Palo-Alto firewall vuln (RCE due to bad unauthenticated XML parsing)

CVE-2026-0310



HEIF Heist (rce via images)

https://heif-heist.com/



Citrix NetScaler (unauth RCE)

CVE-2026-107406

Then according to Kevin Beaumont "Btw Citrix patched this in their hosted cloud offering earlier today, then marked it as not vulnerable. It was.".

PitScaler https://pitscaler.com/



Use after free in WebGL in Google Chrome

CVE-2026-87464



KVM escape to root :(

https://cybernews.com/security/critical-kvm-zero-day-vulnerability-allows-vm-escape/



Atlassian arbitrary file access CVE-2026-21589

https://confluence.atlassian.com/security/cve-2026-21589-arbitrary-file-access-vulnerability-impacts-multiple-products-1870495748.html



GitLab 10/10 via regex in their CI/CD

CVE-2026-97229

https://www.bleepingcomputer.com/news/security/gitlab-warns-of-max-severity-rce-flaw-in-regex-compiler-engine/



Another one (unauthenticated arbitrary file read)

CVE-2026-85706

https://docs.gitlab.com/releases/patches/patch-release-gitlab-19-3-2-released/#cve-2026-85706---path-traversal-issue-in-repository-commits-api-impacts-gitlab-cee

Dell gifting everyone root

https://www.bleepingcomputer.com/news/security/new-dell-system-update-flaw-lets-hackers-gain-root-privileges/



Breaches



Ledger wallets from certain retailers have some extra hardware

https://coinpedia.org/news/ledger-crypto-theft-86-9-million-reportedly-drained-across-98-wallet-addresses/



Military personnel data was stolen

Vulnerability in the Defense Manpower Data Center system

https://www.militarytimes.com/news/pentagon-congress/2026/09/24/military-personnel-data-exposed-in-breach-agency-warns/



Trump Mobile was popped by BYOD



International Cyber Digest
@IntCyberDigest

‼️ BREAKING: Trump Mobile customers have had their personal data leaked by ransomware gang BYOD. The dump covers 3,615 people and includes names, emails, phone numbers, home addresses and order details.

The gang says the company answered news of the breach with "We have no team to handle this."

The leak includes the Trump Organization's own CIO, who oversees its information security.

People listed in the data confirmed their details are accurate and BYOD claims it still has access to Trump Mobile's backend, Straight Arrow News reports.

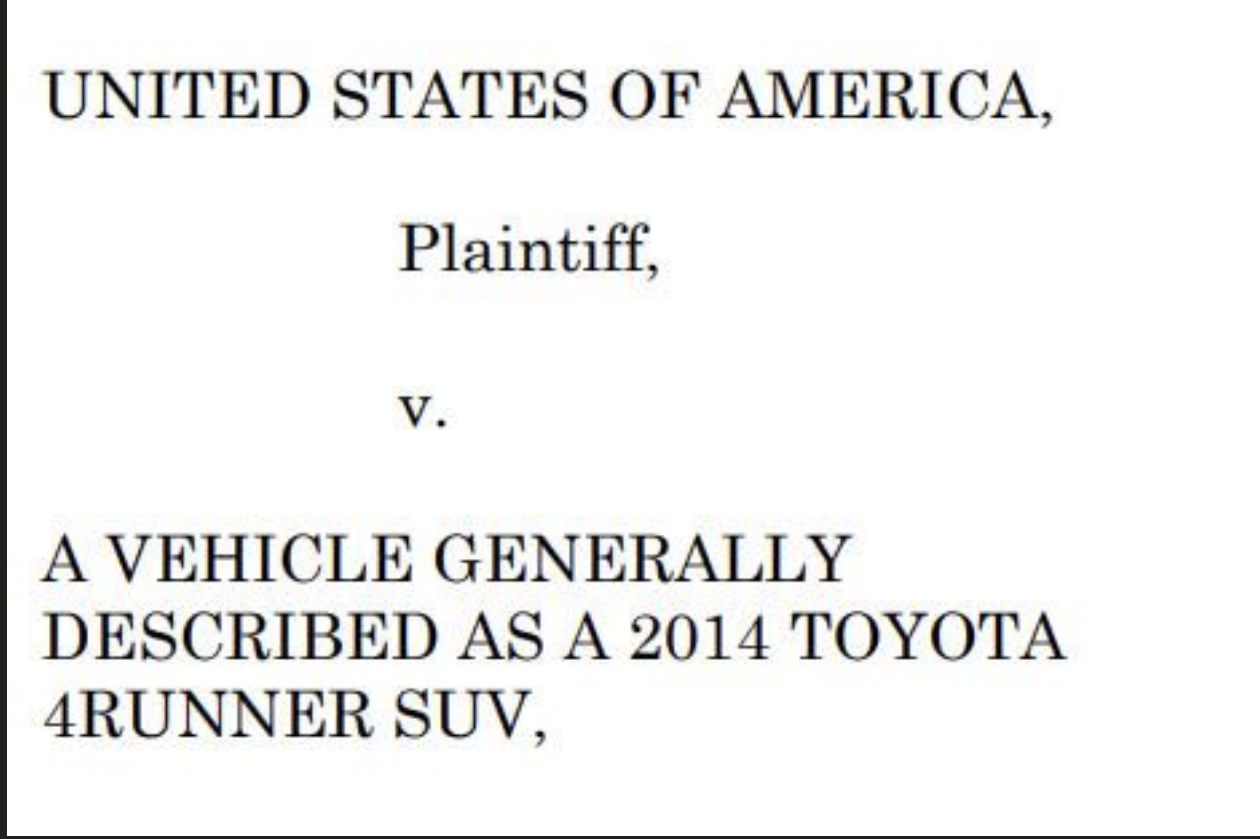
Someone managed to obtain counterfeit TLS certs for Google

https://arstechnica.com/security/2026/10/hackers-obtain-counterfeit-tls-certificates-for-google-and-other-large-services/



Poetry (PoeLLM) malware infected 3k+ servers

https://www.theregister.com/security/2026/10/07/poetry-is-the-new-ai-security-threat-as-poellm-malware-infects-3k-servers/5301672



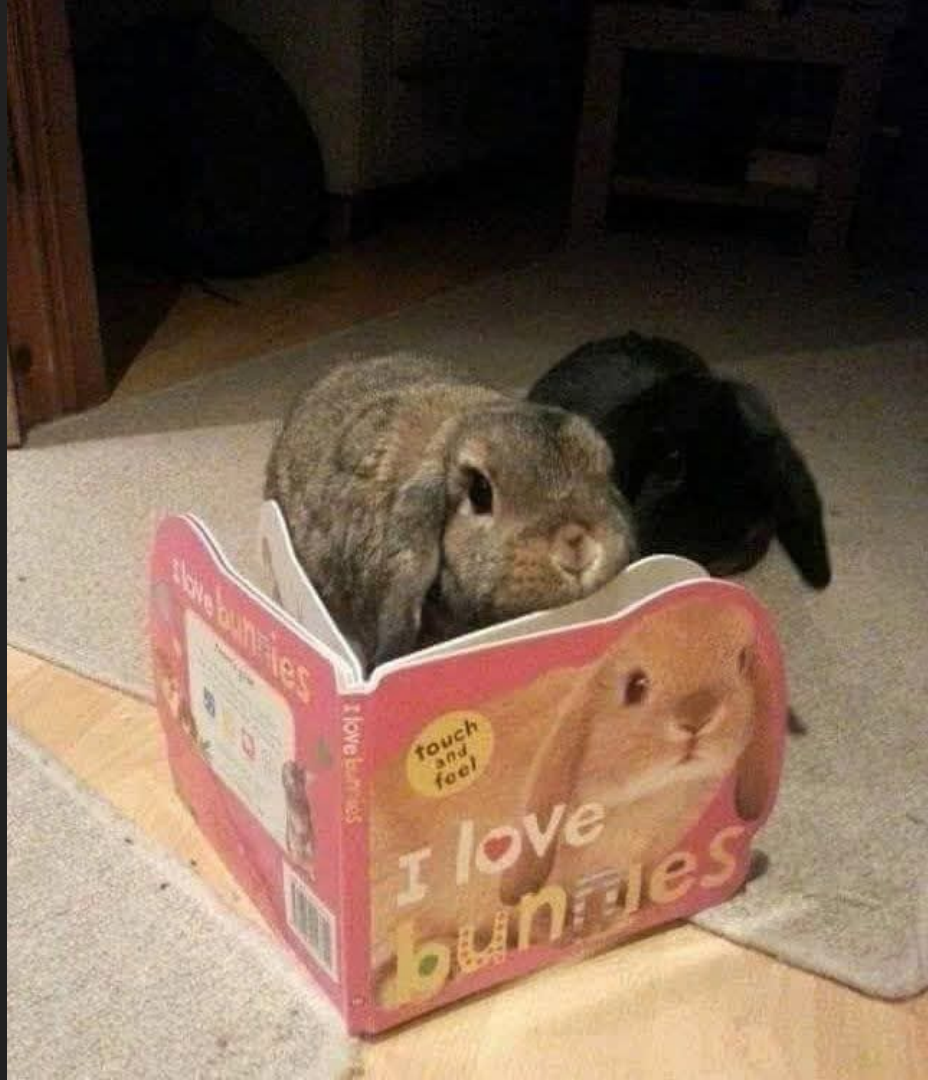
Cyber attack shuts down refrigerators at French supermarkets

https://www.bleepingcomputer.com/news/security/cyberattack-shuts-down-refrigerators-at-french-supermarkets/



ShinyHunters popped the FBI’s PeopleSoft

https://www.404media.co/we-hacked-the-fbi-hackers-say-they-have-data-on-all-fbi-employees/



The FBI fired the scapegoat who didn’t patch in time

https://www.reuters.com/technology/accenture-contractor-removed-fbi-following-damaging-data-breach-sources-say-2026-10-06/



Supposedly Iran took control of some boats

https://www.techradar.com/pro/security/fbi-confirms-two-texas-bound-oil-tankers-hit-by-hackers-who-disabled-coms-and-put-the-engines-into-overdrive-and-iran-is-possibly-to-blame



IDScan.com confirmed the breach I mentioned last month

https://techcrunch.com/2026/09/10/id-verification-giant-idscan-confirms-data-breach-with-more-than-150-million-drivers-licenses-stolen/

Law enforcement action



“Reformed hacker” was arrested in the ShinyHunters investigation

https://www.reuters.com/world/amsterdam-man-arrested-shinyhunters-hacking-investigation-police-say-2026-09-28/



Authorities seize KillSec leak site (Operation KillSwitch)

Authorities seize KillSec leak site, identify 16-year-old as suspected leade. (Operation KillSwitch).

The German-led international operation secured at least 110 terabytes of data and led to three provisional arrests in an investigation into roughly 1,000 suspected attacks worldwide.

MonsterCloud was just paying ransomware groups and lying about it

https://www.theregister.com/cyber-crime/2026/10/08/ransomware-fixer-claimed-he-could-decrypt-files-allegedly-defrauded-clients-instead/5301831



Someone built an ALPR system for tracking cops

https://www.gadgetreview.com/youtuber-builds-system-that-mimics-flock-to-spy-on-cops-then-the-cops-came-knocking



Empire Market co-creator sentenced to 40 years

For facilitating $430 million in illegal transactions from 2018 to 2020.



Interesting



Lots of out of state searches of KC’s ALPRs

https://www.kcur.org/news/2026-09-21/flock-data-from-kansas-city-kansas-got-searched-1-million-times-in-6-months-whos-looking



Hawley is at least pretending to care

https://www.kcur.org/politics-elections-and-government/2026-09-24/u-s-sen-josh-hawley-of-missouri-raises-privacy-alarms-over-nationwide-ai-camera-network



Netherlands is switching away from MS

https://itsfoss.com/news/netherlands-dawo-initiative/



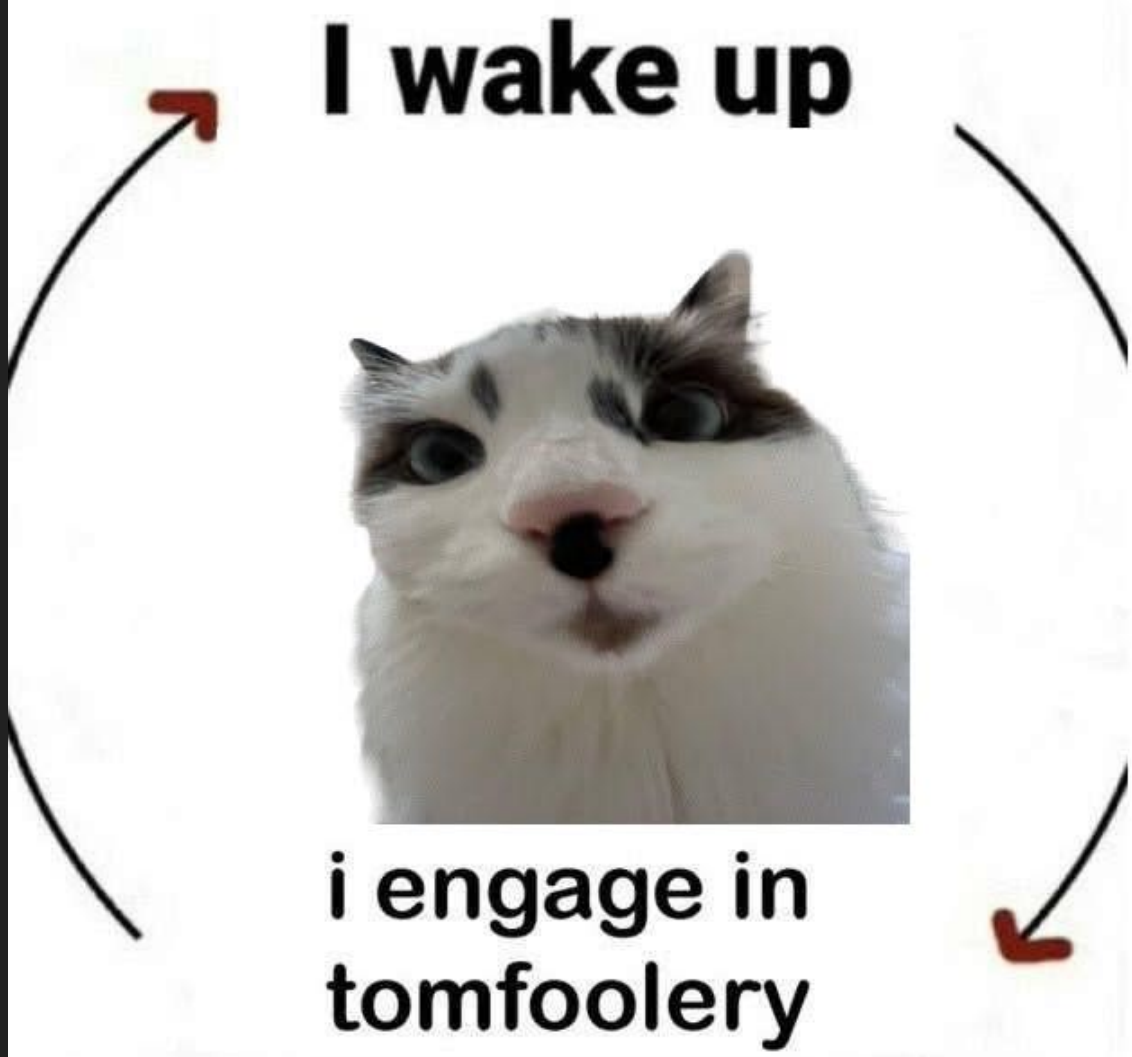
File-notification attacks on Linux

https://lwn.net/Articles/1096431/



Cloudflare bought Deno and is killing it next year

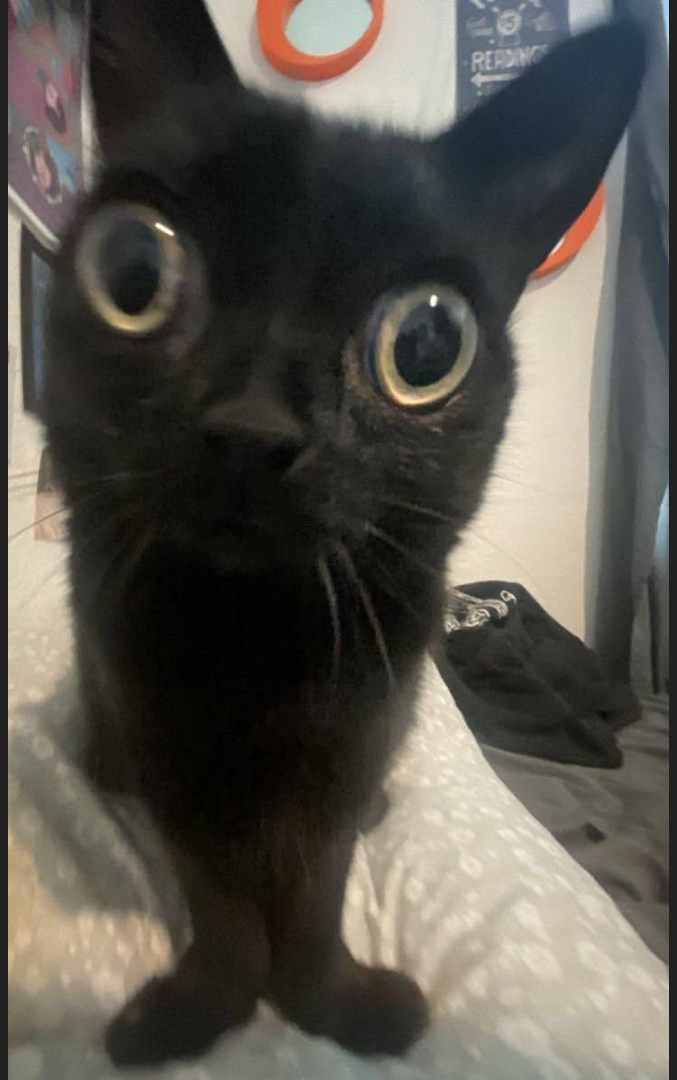
https://deno.com/blog/cloudflare



OpenAI published a bunch of math problems

That they had supposedly solved, and it turns out they haven't solved most of them, and the most interesting thing here is the lack of papers about encryption.

Pretty funny



Meta Muse



(No for real though)

Turns out they gave everyone a free VM that you could use for anything you so desired

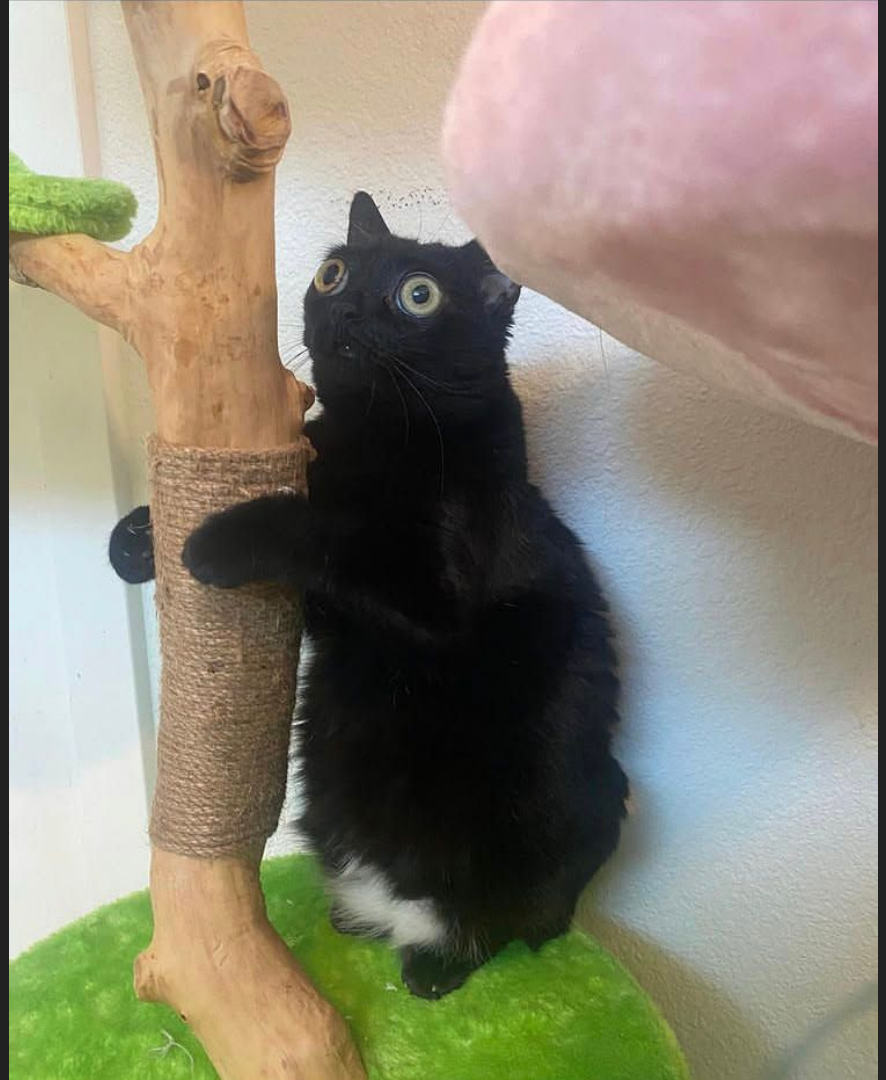
https://infosec.exchange/@jonny@neuromatch.social/117324791539845636

Someone found that a data set of Fable prompts/responses they bought from a router had creds to a bunch of companies and governments (shocking).

Misc



AI is now SI.



Marc Benioff is a cuck of enormous proportions



Marc Benioff
@Benioff

X.com

The era of Super Intelligence is here. AIForce is officially SIForce.



Salesforce

21:39 · 09/10/2026 · **193K** Views

424 259 1.3K 179

OpenAI is paying people to read your chats

https://www.404media.co/inside-project-lily-the-humans-reading-your-chatgpt-chats/



Microsoft doesn’t care about you

https://www.theregister.com/saas/2026/09/28/microsoft-tells-nonprofits-their-deleted-m365-data-isnt-coming-back/5299433



Amazon claimed we wouldn’t notice if their DC got hit with a missile

https://arstechnica.com/gadgets/2026/09/iran-strikes-on-amazon-data-centers-caused-permanent-loss-of-customer-data/



Yandex DC got droned out of existence



DNS Root Zone Begins Using New Key Signing Key as of Sunday

https://www.iana.org/news/2026/root-zone-begins-using-new-ksk-2026

Stole is such a strong word

https://www.404media.co/hackers-stole-flocks-camera-software-revealing-how-the-company-tracks-cars-and-people-2/



This is really a “huh?” type of thing

https://techcrunch.com/2026/09/14/sources-say-automattics-board-is-out-after-failed-attempt-to-oust-ceo-matt-mullenweg/



Actually good news



Parkville suspended it’s Flock program

https://www.kctv5.com/2026/09/12/parkville-suspends-flock-camera-program-amid-privacy-concerns/



Federal judge ruled a Flock search was unconstitutional

https://www.404media.co/federal-judge-rules-a-flock-search-was-indiscriminate-mass-surveillance-and-unconstitutional/



Very very bad



Paragon (the spyware company) apparently has even fewer guardrails than NSO Group (another spyware company).



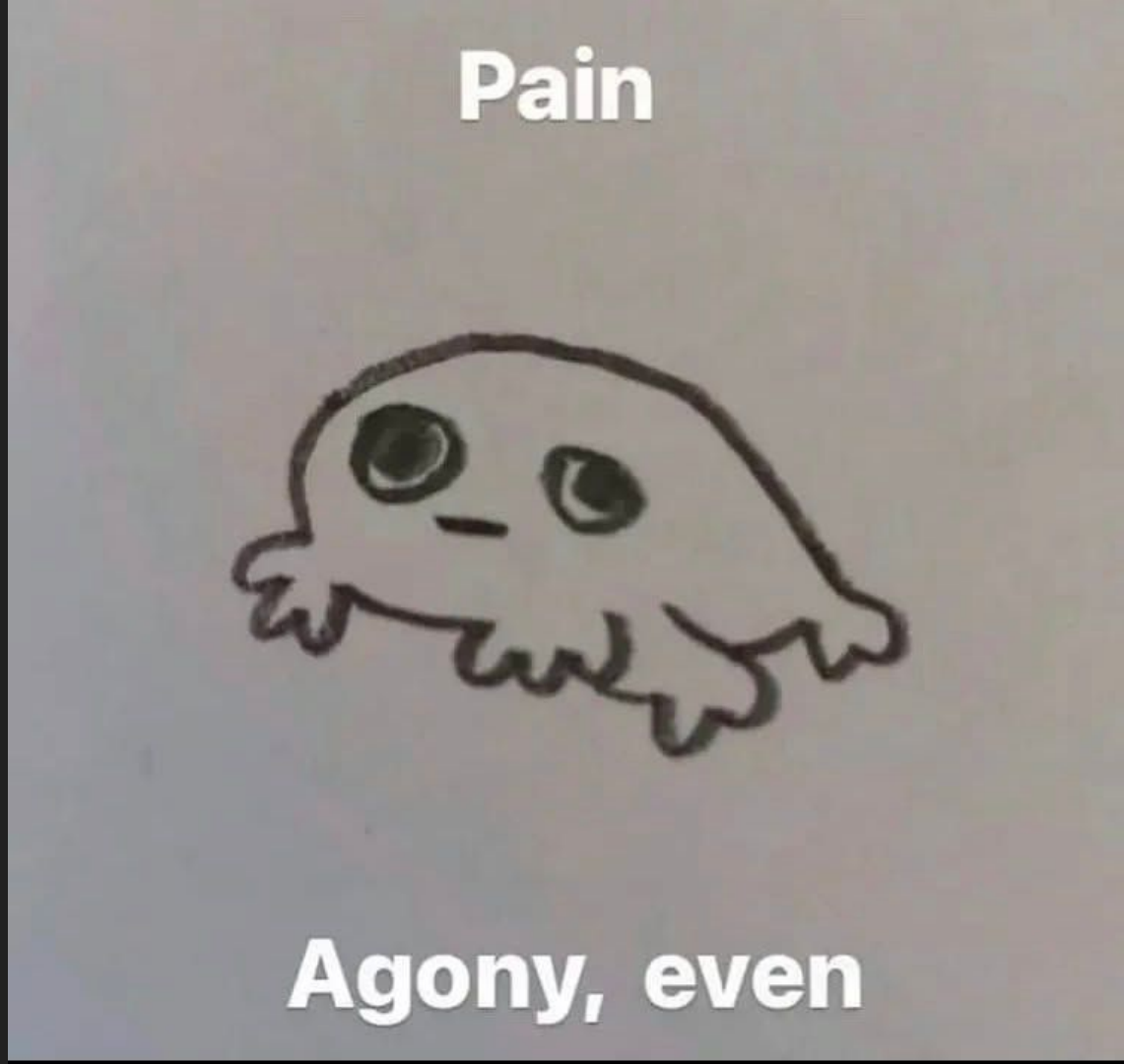
Trump admin is using the HIDTA (High Intensity Drug Trafficking Area) to aggregate ALPR data

https://www.404media.co/how-cities-are-forced-to-funnel-license-plate-data-to-a-massive-federal-surveillance-program-hidta/



DHS is predictive policing based on financial habits

https://www.404media.co/a-secretive-dhs-predictive-policing-unit-is-analyzing-americans-financial-habits-and-pulling-them-over/



ALPR installers calling the cops on people watching them

https://www.investigatetv.com/2026/09/08/flock-worker-calls-police-investigatetv-reporter-filming-public-camera-installation/



Someone figured out how to keep iPhones from rebooting and sold it to cops

https://www.404media.co/cops-can-bypass-iphone-automatic-inactivity-reboot-graykey/



Thanks for listening

You can find me and my stuff at segotari.com (including the slides you just saw)

